Vendor evaluation checklist: 26 questions

For your breach monitoring, domain monitoring, brand protection and perimeter vendor.
Ask to see the work on real data: that way every answer can be checked.

☐ Solid answer ☐ Red flag — Tick as you go through the call

01 DATA QUALITY AND CREDIBILITY

☐ ☐ **01 Do you detect fake and generated leaks — and how exactly?**
Red flag: "we have filters" with no process behind it; a repackaged old set passed off as a new breach.

☐ ☐ **02 How do you establish freshness and the real date of compromise?**
Red flag: "date added" passed off as "date breached"; findings dismissed as old without checking whether the password still works.

☐ ☐ **03 Do you work with stealer logs — and how?**
Red flag: public combo lists only; just passwords pulled from the log; after a stealer incident the advice is "change the password".

☐ ☐ **04 Is your "dark web" public onion sites — or real closed platforms?**
Red flag: a public onion site presented as a closed source; no capacity to pull and process large dumps.

☐ ☐ **05 Which sources do you monitor — can you name a concrete list?**
Red flag: a vague "many sources" with no list; collection limited to public channels and aggregators.

02 DEPTH OF ANALYSIS

☐ ☐ **06 Do you account for 2FA/MFA bypass risk based on breach data?**
Red flag: the advice stops at a password reset, ignoring that a stolen session bypasses MFA entirely.

☐ ☐ **07 Do you do reverse checks?**
Red flag: "password no longer works, risk closed"; personal and corporate accounts never linked; privilege behind a login like admin goes unnoticed.

☐ ☐ **08 What scope of data do you actually process from a breach?**
Red flag: only login, password and URL are stored, everything else normalised away; you get "this email was found" with no context.

☐ ☐ **09 Breaches as an investigation tool — do you take those cases?**
Red flag: they can only show a list of leaks; forensics and insider work are out of scope.

☐ ☐ **10 Coverage depth: basic leaks only — or recon through an attacker's eyes?**
Red flag: only the breach database is examined; ports, shadow IT, secrets in code and mobile builds stay out of scope.

03 SIGNAL, NOISE AND DELIVERY

☐ ☐ **11 How do you cut the noise and confirm findings?**
Red flag: you spend weeks tuning filters; brand search comes down to grep on a keyword.

☐ ☐ **12 What do we get at the end — a counter dump or a report built around our goals?**
Red flag: a line saying "an email was found" with no priority; an interface overloaded with modules that never reduces risk.

☐ ☐ 13 **Do you take the work on — or does the client handle it?**

Red flag: the "here's an alert, you deal with it" model; a portal that takes weeks to learn.

04 SPEED, INTEGRATIONS, PRICE AND TRUST

☐ ☐ 14 **What is the lag between event and finding — and what drives priority?**

Red flag: one batch cycle, weekly or monthly, with no prioritisation; weeks between a finding and any reaction.

☐ ☐ 15 **Do you have an API and integrations — and in what form is data delivered?**

Red flag: report download only; no API, or it sits behind a separate paid module.

☐ ☐ 16 **How do pricing and licensing work?**

Red flag: licences by assets, export caps, expensive add-ons.

☐ ☐ 17 **Is there a pilot or POC on real data?**

Red flag: a polished demo on someone else's data; to see anything you fill in questionnaires and wait months for approval.

☐ ☐ 18 **Where is our data processed — is it run through public AI and the cloud?**

Red flag: data run through public AI and cloud; one shared environment for all clients; the vendor itself has had incidents; a model conclusion with no grounds in the record's data; a model decision no person reviews.

05 BRAND PROTECTION

☐ ☐ 19 **How do you find look-alikes of our brand?**

Red flag: one generation algorithm and a spreadsheet of hundreds of thousands of names; a substring search on the name; certificates and the day's fresh registrations are not watched.

☐ ☐ 20 **What tells you a domain is dangerous?**

Red flag: "looks similar" as the only ground; mail, favicon, screenshot and registration go unchecked; a decision with no visible reason.

☐ ☐ 21 **How many lines does our team end up reviewing?**

Red flag: the whole list "for review"; the client works out priority; a decision has no grounds.

☐ ☐ 22 **How do you show what exactly was checked?**

Red flag: an empty cell reads as "clean"; a failed source looks like "no look-alikes".

06 CASES AND TAKEDOWN

☐ ☐ 23 **What do we get to hand a finding to lawyers and the registrar?**

Red flag: a screenshot in an email; the client gathers evidence alone; no hashes, capture dates or action log.

☐ ☐ 24 **You found a fake mobile app — what do you do next?**

Red flag: just a link to the app store; nobody takes the code apart or knows what was changed and where the data goes; the takedown is left to the client.

07 PERIMETER

☐ ☐ 25 **Do you track changes to our own perimeter?**

Red flag: a one-off scan with no history; an inventory the client keeps alone; certificates, SPF/DMARC and open storage are out of scope.

08 REPORTING AND THE REGULATOR

☐ ☐ 26 **Can you show a regulator what work was done, by whom and when?**

Red flag: a report of counters with no action log; history can be rewritten after the fact; a past state of the perimeter cannot be restored.

How Hirdman answers the same 26 questions.

Every line below is on hirdman.pro. Ask us to show any of it on your own data.

DATA QUALITY AND CREDIBILITY

01 **Every set is validated before it enters monitoring.** Source reputation, pattern analysis for generated records and a comparison with known dumps catch a repack.

02 **Two dates, kept apart:** when a record appeared in the sources we monitor and the claimed breach date, each with a confidence level. An old password is checked for whether it still works.

03 **A label of their own and extra response steps.** Cookies, sessions and tokens stay with the login and feed the reverse check and, under contract, tests of your MFA.

04 **Long-standing access to closed onion services and underground forums,** entry by invitation or at a high price. We download and parse dumps that weigh terabytes.

05 **Thousands of sources:** breach databases, closed forums, data markets, messenger channels, ransomware group sites, infostealer logs and early signals from security and DLP channels. 106+ bn records, plus 46 bn raw records.

DEPTH OF ANALYSIS

06 **A stolen session counts as a way past MFA.** The fix covers revoking sessions, rotating tokens and re-authentication; under contract we test how well your MFA holds.

07 **Yes, round after round.** One identifier runs through every source; personal and corporate accounts are linked and a login like admin is traced to its rights. One account yields 300–500 new data points.

08 **The full context of each breach:** cookies, sessions, keys, tokens, documents, mail and full URLs with path and port. One account from different breaches is kept apart, so you see its history.

09 **Yes, together with you.** Forensics, OSINT on the people involved and leak analytics: who created which passwords, when, and where the leaked data overlaps.

10 **Leaks and the attack surface, one team:** related projects, subdomains, open ports, shadow IT, secrets in code and APK builds. In our Storybook case: 711 secrets on a domain with no leaked email or password.

SIGNAL, NOISE AND DELIVERY

11 **Only confirmed findings reach your portal.** Every match is checked for belonging to your company by domain, infrastructure, employees and the context of the record.

12 **A risk tier and a decision for every finding:** fix now, this week, can wait, with the evidence and the fix. The portal report comes in 7 profiles, a four-page executive version among them.

13 **We do.** You send a domain; collection, verification, reverse checks, ranking and the re-check of each fix run on our side.

SPEED, INTEGRATIONS, PRICE AND TRUST

14 **A confirmed risk reaches you at once** through the agreed channel, and the report follows. Processing runs around the clock; on Enterprise, VIP accounts are checked every hour.

15 **Yes: an API with verified findings, risk tiers and decisions,** plus alerts via SIEM or email and an integration with whitespots.io. Each finding carries its status through to the re-check.

16 **Scope agreed up front.** No per-asset or per-user licences, no export limits, no paid modules and no charge for talking to an analyst.

17 **A free check on your own data,** set next to what your current service shows: the first picture in about 30 minutes, a surface report in 1–2 days. The demo portal is open to anyone.

18 **On hardware we own, with local models.** Client data never passes through public AI services or third-party clouds; your portal runs on your server or one we rent, encrypted with its own key.

BRAND PROTECTION

19 **Spelling permutations, look-alike characters, other zones and your brand plus another word,** and certificates issued for your names, tracked in near real time.

20 **Many signals, weighed together:** typosquatting, combosquatting, look-alike characters, DNS and mail records (SPF, DKIM, DMARC), registration, a screenshot and icon beside your site, redirects, certificates in the transparency logs, hosting and parking. An analyst writes down the grounds.

21 **A short list of decisions.** Names that share an icon, a registrar or an address are worked as one operator; your portal shows what needs action, with a verdict and an urgency in words.

22 **Each name carries its measurements and evidence.** Names that were never registered are counted and set aside; disputed ones carry the analyst's written grounds.

CASES AND TAKEDOWN

23 **A takedown package:** originals, hashes, timestamps and an action log, ready for registrars, app stores and lawyers.

24 **We take the clone apart:** what it changes and where the data goes. The takedown package for the app store follows.

PERIMETER

25 **Your perimeter stays under watch:** new subdomains, assets, ports and services. On Enterprise, names, addresses, ports, owners and technologies sit in one inventory with a change feed.

REPORTING AND THE REGULATOR

26 **A record of the work:** each finding keeps its status from reported to fixed and re-checked, the portal report has a compliance version, each takedown case an action log.

Want to compare on your own data?

We show the findings for your domain with no commitment. The core portal is open right now: demo.hirdman.pro, login demo, password demo.

Request a free check

info@hirdman.pro

Check yourself · scan.hirdman.pro

Demo portal · demo.hirdman.pro · login demo · password demo